Flag 10 of 18: Privileged Service Account on the Database Server

OAuth Heist scenario · Cymbal Investments · Google SecOps SIEM

Question

Armed with credentials discovered in the stolen document, what privileged service account did the attacker authenticate to from the compromised employee workstation to access the internal database server?

Answer

svc_dbadmin

Evidence

This answer was accepted as correct in the platform. The supporting events appeared in the later database-server searches:

- `USER_LOGIN` for `svc_dbadmin` using `NtLmSsp`, with `CYM-DATA-WS-007` as the logon source (list time 21:47:26).
- `wsmprovhost.exe` launched by `svchost.exe` on `CYM-DB-01.cymbal.corp` under `svc_dbadmin`, a WinRM remote session (list time 21:47:41).
- `sqlcmd.exe` and `zstd.exe` then ran under the same account on `CYM-DB-01`, and the same account made the outbound upload connection.

How it was found

Window: Oct 15 20:00 to Oct 19 00:00 UTC. Searching for the service-account naming pattern across the Cymbal namespace listed every event for these accounts:

```
principal.namespace = "Cymbal"
AND (principal.user.userid = /svc/ nocase OR target.user.userid = /svc/
nocase)
```

The results showed `svc_backup` (the file server) and `svc_dbadmin` (the database server).

Note

The logon event names `CYM-DATA-WS-007` as the source. If the platform asks for the source host, check that event rather than assuming the source was elena.rostova workstation (`10.240.12.65`).

Next pivot

Follow svc_dbadmin on CYM-DB-01 to see what it exported.